

CAHIER D'ANALYSE

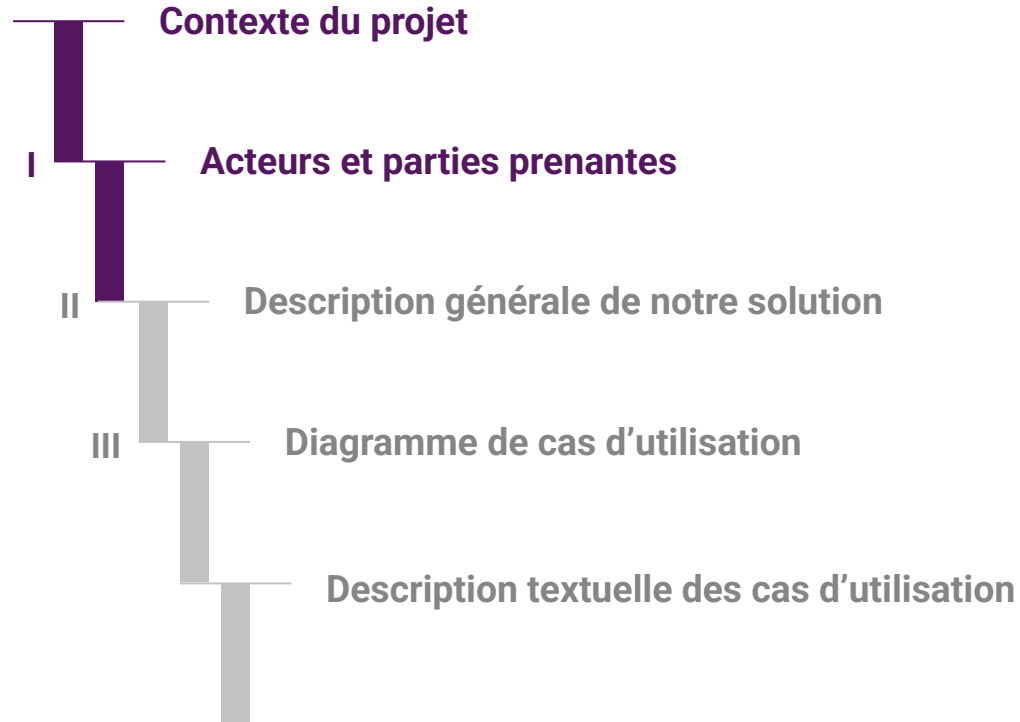
Projet : Gestion des secrets avec Barbican

Groupe 6 :

- ANABA NGOUMOU Rachel
- HARVIS LANDRY Fotseu Fonkwa

Sous la supervision de :
M. NGUIMBUS Emmanuel

PLAN

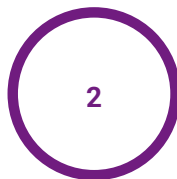


Contexte du projet

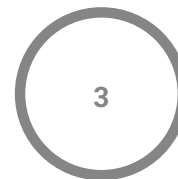
Notre projet, à savoir la gestion des secrets avec Barbican, est une réponse aux constats suivants :



La complexité de l'authentification des applications tierces pour pouvoir accéder aux services de Barbican; seuls les utilisateurs ou les services OpenStack ont des comptes.



Le renouvellement manuel des clés API et des certificats SSL/TLS; causant l'interruption des services qui en dépendent en cas d'expiration.



L'absence de notification pour signaler les changements de clés API ou de certificats aux applications et aux utilisateurs, ainsi que les potentiels erreurs.

Contexte du projet

Nos objectifs principaux sont donc :

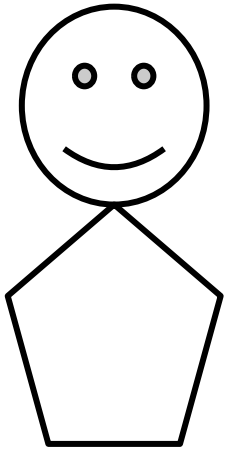
A decorative graphic on the left side of the slide, consisting of three horizontal lines and three vertical bars of increasing height, creating a staircase effect.

Standardiser l'authentification des applications tierces

Automatiser le renouvellement des certificats SSL/TLS et des clés API

Monitorer les applications tierces, la validité de leurs clés API et certificats SSL/TLS.

Acteurs et parties prenantes



**Acteurs
primaires**



Personnes (administrateur développeur) : qui visualisent et gèrent les secrets et les applications via une interface.



Applications tierces : qui viendront solliciter des interactions avec Barbican.



Orchestrateur interne : qui exécute toutes les tâches internes du système.



**Acteur
secondaire**



Barbican : qui permet de générer, de stocker, d'accéder et de manipuler les secrets.



Autorité de certification (CA) : qui fournit des certificats signés et gère leur validité juridique/technique.



Keystone : qui gère les identités.

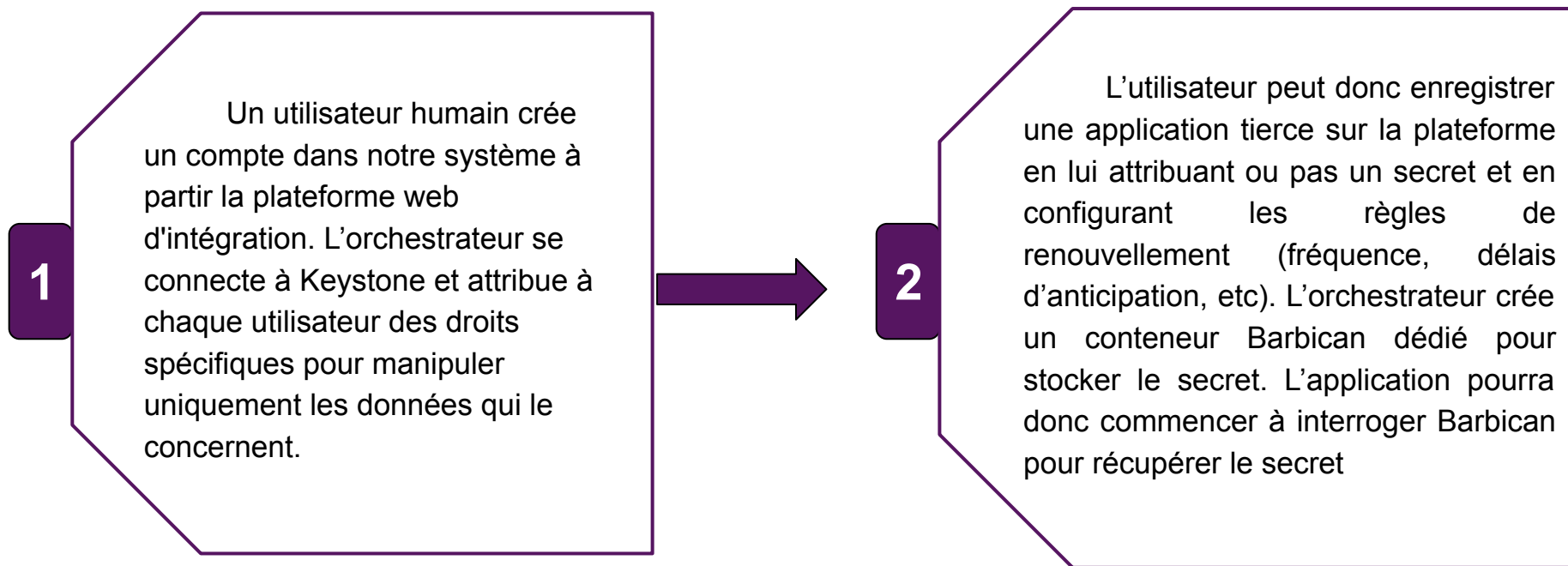


Service mail : qui contribue à l'envoi des mails.

Description générale de notre solution

Notre solution est un système centralisé qui automatise et sécurise l'intégralité du cycle de vie des secrets (clés API et certificats SSL/TLS) au sein d'une entreprise.

Son flux de fonctionnement est le suivant :



Description générale de notre solution

3

L'orchestrateur scanne quotidiennement Barbican. Lorsqu'un secret atteint sa date de renouvellement, le processus s'enclenche et l'orchestrateur interagit avec Barbican ou une autorité de certification sans intervention humaine. L'application récupère la nouvelle version du secret (en cas de latence du service tiers, elle peut temporairement utiliser l'ancienne version contenue dans le conteneur).



4

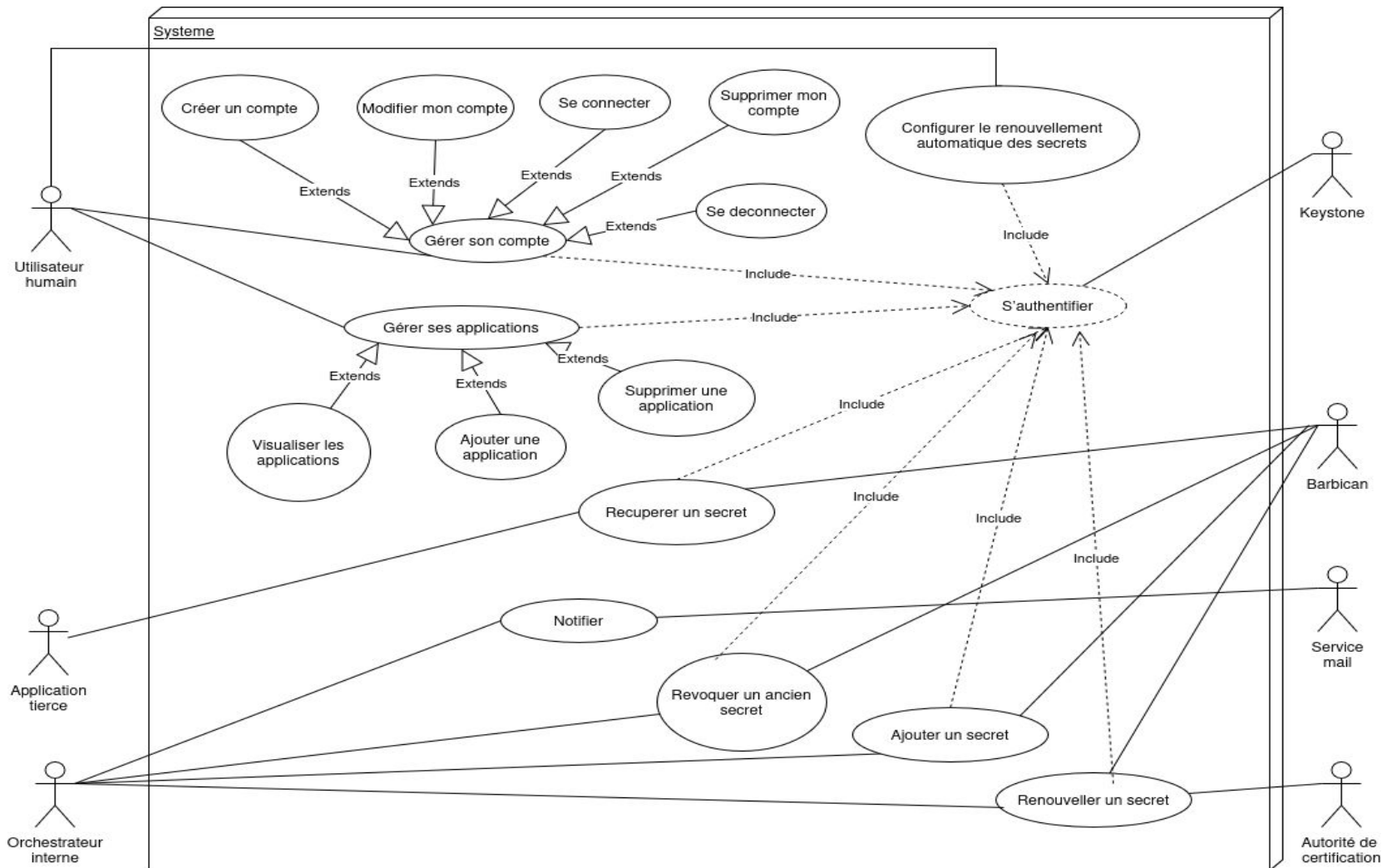
L'orchestrateur analyse les logs d'accès de Barbican pour confirmer que l'application utilise désormais la nouvelle version du secret. Une fois la preuve de migration obtenue, l'orchestrateur désactive l'accès à l'ancien secret puis le supprime définitivement de Barbican.

Description générale de notre solution : fonctionnement concret avec Orange Money

1. Un client veut payer : l'application de vente passe par notre système, elle s'identifie et reçoit un Token.
2. A l'aide de son Token, l'application récupère la **Clé Secrète Orange Money** contenue dans Barbican en passant toujours par notre système.
3. L'application utilise la clé pour valider le paiement auprès d'Orange.
4. Une fois la transaction finie, la clé est effacée de la mémoire vive de l'application.

Bénéfice majeur : Si un pirate s'introduit sur le serveur de l'application de vente, il n'y trouvera aucune clé Orange Money à voler, car elles ne "vivent" dans l'application que quelques millisecondes durant la transaction.

Diagramme de cas d'utilisation



Description textuelle des cas d'utilisation de l'utilisateur humain

Description textuelle des cas d'utilisation

Créer un compte

Acteur : Utilisateur humain

Objectif : Créer un compte un nouvel utilisateur dans le système.

Pré-condition : L'utilisateur humain n'a pas encore de compte.

Scénario :

1. L'utilisateur entre l'URL de la plateforme dans le navigateur puis valide.
2. Un formulaire de connexion s'ouvre.
3. L'utilisateur clique sur le lien « S'inscrire » en bas du formulaire de connexion et le formulaire d'inscription s'ouvre.
4. L'utilisateur saisit les informations requises (nom, pseudonyme, adresse mail, mot de passe, confirmation du mot de passe) puis clique sur le bouton « Confirmer »
5. Si les informations saisies sont invalides, le formulaire ne disparaît pas et les champs contenant les erreurs sont mis en rouge décrivant l'erreur en dessous (mot de passe faible, pseudonyme déjà existant).
6. Si toutes les informations sont valides, le formulaire disparaît et le formulaire de connexion est affichée.

Post-conditions : un nouveau compte utilisateur est créé et l'administrateur ou le développeur est renvoyé à la page de connexion.

Description textuelle des cas d'utilisation

Se connecter

Acteur : Utilisateur humain

Objectif : Accéder à son compte sur la plateforme web d'intégration

Pré-conditions : L'utilisateur humain a déjà créer un compte sur la plateforme et possède des identifiants valides..

Scénario :

1. L'utilisateur entre l'URL de la plateforme dans le navigateur puis valide.
2. Un formulaire de connexion s'ouvre.
3. L'utilisateur saisit ses identifiants (pseudonyme, mot de passe) puis clique sur le bouton « connexion ».
4. Si les identifiants sont invalides, un message s'affiche sur le formulaire (pseudonyme ou mot de passe incorrects. Veuillez réessayer).
5. Si le nombre de tentatives de connexion est supérieur à 05, les champs de saisie sont bloqués et un message s'affiche sur le formulaire (Nombre de tentatives de connexion élevé. Veuillez réessayer dans X minutes).
6. Si les identifiants sont valides, la page d'accueil s'affiche contenant un menu de navigation latéral à gauche et un tableau de bord (Nombre d'applications et de secrets) dans le corps de la page.

Post-condition : L'utilisateur a accès à la page d'accueil de son compte.

Description textuelle des cas d'utilisation

Modifier son compte

Acteur : Utilisateur humain

Objectif : Mettre à jour ses informations personnelles ou ses paramètres de compte.

Pré-condition : L'utilisateur humain est connecté.

Scénario :

1. Dans le menu de navigation latéral, l'utilisateur clique sur « Modifier mon compte »
2. Le corps de la page se rafraîchit et affiche 02 sections à savoir « Modifier mon identité » (nom, pseudonyme, adresse mail) et « Modifier mon mot de passe » (ancien mot de passe, nouveau mot de passe, confirmer le nouveau mot de passe).
3. L'utilisateur remplit la section qui l'intéresse puis clique sur le bouton « Modifier ».
4. Si les informations sont invalides, les champs contenant les erreurs sont mis en rouge décrivant l'erreur en dessous (mot de passe faible, pseudonyme déjà existant, ancien mot de passe incorrecte, le nouveau mot de passe doit être différent de l'ancien).
5. Si les informations sont valides, un message de succès s'affiche.

Post-condition : Les informations du compte sont mises à jour.

Description textuelle des cas d'utilisation

Ajouter une application

Acteur : Utilisateur humain

Objectif : Enregistrer une nouvelle application tierce qui utilisera les services de gestion des secrets.

Pré-conditions : L'utilisateur est connecté et authentifié, Barbican et Keystone sont fonctionnels

Scénario :

1. Dans le menu de navigation latéral, l'utilisateur clique sur « Gérer mes applications ».
2. Le corps de la page se rafraîchit et affiche la liste des applications déjà ajoutées (s'il y'en a) et le bouton « Ajouter une application »
3. L'utilisateur clique sur « Ajouter une application »
4. Un formulaire d'ajout d'application s'ouvre contenant plusieurs champs (nom, description, type de secret (Clé API ou certificat SSL/TLS), noms de domaines attachés et un bouton « Générer un secret »). Seul le champ nom est obligatoire. Si le champ valeur du secret est rempli, le bouton de génération est bloqué et vice versa.
5. L'utilisateur remplit le formulaire puis clique sur le bouton « Valider ».
6. Si le nom de l'application existe déjà, ce champ est mis en rouge décrivant l'erreur en dessous (Ce nom existe déjà. Veuillez saisir un autre nom).
7. Si les informations sont valides, un message de succès s'affiche et la liste des applications s'actualise.
8. Le nombre d'applications augmente au niveau du tableau de bord.
9. Si un secret a été ajouté avec l'application, le nombre de secrets augmente également.

Post-condition : Une nouvelle application tierce est enregistrée dans le système et peut commencer à utiliser et stocker des secrets.

Description textuelle des cas d'utilisation

Visualiser les applications

Acteur : Utilisateur humain

Objectif : Consulter la liste et les détails de toutes les applications tierces enregistrées.

Pré-conditions : L'utilisateur humain est connecté, Barbican et Keystone sont fonctionnels.

Scénario :

1. Dans le menu de navigation latéral, l'utilisateur clique sur « Gérer mes applications ».
2. Le corps de la page se rafraîchit et affiche la liste des applications (ID, nom de l'application, nombre de secrets, pour chaque type de secret : durée de validité et date d'expiration, le code secret de l'application, les boutons « Supprimer », « Générer un secret », « Renouveler le secret »).
3. L'utilisateur peut rechercher une application dans la barre de recherche. Il peut afficher les applications en fonction d'une période de validité ou d'expiration du secret.

Post-conditions : La liste des applications enregistrées s'est affichée et l'utilisateur les a consultées.

Description textuelle des cas d'utilisation

Supprimer une application

Acteur : Utilisateur humain

Objectif : Supprimer définitivement une application tierce enregistrée et les secrets qui lui sont associés.

Pré-conditions : L'utilisateur est connecté, Barbican et Keystone sont fonctionnels, et l'application à supprimer existe dans le système.

Scénario :

1. Dans le menu de navigation latéral, l'utilisateur clique sur « Gérer mes applications ».
2. Le système affiche la liste des applications avec leurs détails (ID, nom, secrets, etc.).
3. L'utilisateur identifie l'application cible (en utilisant éventuellement la barre de recherche).
4. L'utilisateur clique sur le bouton « Supprimer » situé sur la ligne correspondant à l'application.
5. Une fenêtre de confirmation s'affiche pour demander à l'utilisateur de valider la suppression définitive de l'application et de ses secrets associés.
6. L'utilisateur confirme l'action.
7. Le système supprime les données de l'application, révoque les accès associés et rafraîchit la liste.

Post-conditions : L'application est retirée de la liste et ses secrets sont supprimés de Barbican.

Description textuelle des cas d'utilisation

Configurer le renouvellement automatique des secrets

Acteur : Utilisateur humain

Objectif : Mettre en place les règles et paramètres pour le renouvellement automatisé des secrets.

Pré-conditions : L'utilisateur est connecté.

Scénario :

1. Dans le menu de navigation latéral, l'utilisateur clique sur « Règles de renouvellement des secrets ».
2. Un formulaire s'ouvre, lui demandant de renseigner les options de configuration (la fréquence de rotation, le fichier CSR, le délai d'anticipation, l'application et le secret concernés). Par défaut, la fréquence de rotation et le délai d'anticipation sont définis pour tous les secrets.
3. L'utilisateur saisit les informations requises puis clique sur le bouton « Enregistrer ».
4. Si des champs n'ont pas été remplis, ces champs sont mis en rouge.
5. Si les informations sont valides, un message de succès s'affiche.
6. Les paramètres définis sont affichés dans le corps de la page et peuvent être modifiés en cliquant sur le bouton « Modifier la configuration ».

Post-condition : Le renouvellement automatique est activé et paramétré pour tous les secrets.

Description textuelle des cas d'utilisation

Se déconnecter

Acteur : Utilisateur humain

Objectif : Terminer une session active dans le système.

Pré-condition : L'utilisateur est connecté.

Scénario :

1. Dans le menu de navigation latéral, l'utilisateur clique sur « Déconnexion ».
2. La page d'accueil disparaît et le formulaire de connexion s'affiche.

Post-condition : L'utilisateur n'est plus dans son compte et le formulaire de connexion est affiché.

Description textuelle des cas d'utilisation

supprimer son compte

Acteur : Utilisateur humain

Objectif : Supprimer définitivement son compte du système.

Pré-condition : L'utilisateur humain est connecté.

Scénario :

1. Dans le menu de navigation latéral, l'utilisateur clique sur « Supprimer mon compte ».
2. Un message de confirmation s'affiche demandant à l'utilisateur de saisir son mot de passe.
3. L'utilisateur saisit son mot de passe puis clique sur le bouton « Confirmer ».
4. La page d'accueil disparaît et le formulaire de connexion s'affiche.

Post-condition : Le compte est supprimé du système.

Description textuelle du cas d'utilisation des applications tierces

Description textuelle des cas d'utilisation

Récupérer un secret

Acteur : Application tierce

Objectif : Obtenir la valeur d'un secret stocké.

Pré-conditions : Le secret existe et l'application est autorisée à accéder au secret.

Scénario :

1. Au démarrage ou à l'expiration de son cache local, l'application tierce envoie une requête (ID_secret, code_secret_application) à notre système pour demander à récupérer un secret.
2. L'orchestrateur détecte la demande et récupère le code secret.
3. L'orchestrateur demande un jeton d'authentification de l'application à keystone (ID_application, code_secret_application).
4. Si le code secret est invalide, keystone renvoie un message d'erreur à l'orchestrateur.

Description textuelle des cas d'utilisation

Récupérer un secret (suite)

1. L'orchestrateur envoie un message d'erreur à l'application (Échec de récupération. Vous n'avez pas les droits d'accès à ce secret) puis il notifie l'utilisateur correspondant à cette application sur l'échec de récupération.
2. Si le code secret est valide, keystone renvoie le jeton d'authentification.
3. L'orchestrateur effectue une demande de secret à Barbican (jeton_authentification, ID_secret).
4. Barbican renvoie la structure du conteneur de secret, incluant les références vers le secret courant et l'ancien secret.
5. L'orchestrateur renvoie cette structure à l'application tierce.

Post-conditions : L'application a reçu la valeur du secret, ou une erreur a été signalée.

Description textuelle des cas d'utilisation de l'orchestrateur

Description textuelle des cas d'utilisation

Ajouter un secret

Acteur : Orchestrateur interne

Objectif : Créer un secret pour une application tierce.

Pré-condition : Une demande de création de secret à été initiée, Keystone, Barbican et l'autorité de certifications sont fonctionnels.

Scénario :

1. Un utilisateur initie une demande de génération d'un secret pour une application.
2. L'orchestrateur récupère l'identifiant (ID) de l'application.
3. Si le type de secret est une clé API, l'orchestrateur envoie une requête à Barbican (jeton de l'orchestrateur, ID de l'application) pour qu'il génère un secret.
4. Si le type de secret est un certificat, l'orchestrateur envoie une requête à l'autorité de certification (fichier_CSR) pour générer un certificat.
5. Si les informations du fichier CSR sont incorrectes, l'AC renvoie une erreur. L'orchestrateur récupère l'erreur et notifie l'utilisateur.
6. Si les informations sont correctes, l'AC renvoie le nouveau certificat. L'orchestrateur le récupère puis le stocke dans Barbican.

Post-condition : Un secret a été généré et il est désormais liés à une application.

Description textuelle des cas d'utilisation

Renouveler un secret

Acteur : Orchestrateur interne

Objectif : Remplacer un secret existant par un nouveau sans intervention humaine.

Pré-condition : Le secret existe dans Barbican, la date de renouvellement est atteinte ou une demande de renouvellement à été faite.

Scénario :

1. L'orchestrateur scanne Barbican pour vérifier si le délai d'anticipation d'un secret est atteint.
2. Si ce délai est atteint ou qu'un utilisateur a initié une demande de renouvellement d'un secret, l'orchestrateur récupère l'ID du secret pour identifier l'application à qui il appartient puis il récupère l'identifiant (ID) de l'application.
3. L'orchestrateur s'authentifie chez keystone pour recevoir un jeton d'authentification.
4. Si le type de secret est une clé API, l'orchestrateur envoie une requête à Barbican (jeton de l'orchestrateur, ID de l'application) pour qu'il génère un nouveau secret.
5. Si le type de secret est un certificat, l'orchestrateur envoie une requête à l'autorité de certification (fichier_CSR) pour générer un nouveau certificat.
6. Si les informations du fichier CSR sont incorrectes, l'AC renvoie une erreur. L'orchestrateur récupère l'erreur et notifie l'utilisateur.
7. Si les informations sont correctes, l'AC renvoie le nouveau certificat. L'orchestrateur le récupère puis le stocke dans Barbican.

Post-condition : Un nouveau secret a été généré et il coexiste avec l'ancien jusqu'à révocation.

Description textuelle des cas d'utilisation

Révoquer un ancien secret

Acteur : Orchestrateur interne

Objectif : Désactiver et supprimer un secret obsolète après qu'il a été remplacé ou n'est plus nécessaire.

Pré-conditions : L'ancien secret est identifié, le nouveau secret est déployé avec succès ou une application a été supprimée.

Scénario :

1. Après le renouvellement d'un secret ou après suppression d'une application, l'orchestrateur récupère les références vers le secret courant et l'ancien secret de ce secret dans Barbican et scanne les logs de Barbican pour vérifier si l'ancien secret est encore appelé.
2. Si l'ancien secret est encore appelés, il continue de scanner les logs à intervalles de temps.
3. Si l'ancien secret n'est plus appelé, il demande à Barbican de le désactiver et de le supprimer après un certains nombre de jours.
4. Si la désactivation échoue, Barbican envoie une erreur à l'orchestrateur et l'orchestrateur notifie l'utilisateur.

Post-condition : L'ancien secret est définitivement supprimé.

Description textuelle des cas d'utilisation

Notifier

Acteur : Orchestrateur interne

Objectif : Informer les utilisateurs humains sur les événements importants liés aux secrets (renouvellement, erreur).

Préconditions : Un événement déclencheur s'est produit (renouvellement réussi, erreur).

Scénario :

1. L'orchestrateur scanne les logs du système, s'il détecte un nouvel événement (ajout ou renouvellement d'un secret, suppression d'une application, création d'un nouveau compte, suppression d'un compte, erreur diverses) il récupère l'adresse mail de l'utilisateur et le nom de l'application liés à cet événement.
2. Il envoie une requête au service de mail (Titre_message(alerte, succès), adresse_mail, nom_application, description).
3. S'il y'a interruption, le service mail envoie une erreur et l'orchestrateur la stocke dans les logs.
4. S'il n'y a pas d'interruption, l'utilisateur reçoit un mail.

Post-condition : Les utilisateurs humains reçoivent une notification sur l'événement qui s'est produit.

MERCI POUR VOTRE ATTENTION